



亚奥理事会官方合作伙伴

OFFICIAL PRESTIGE PARTNER OF THE OLYMPIC COUNCIL OF ASIA

一、安全通告

近日，监测到Linux Kernel Dirty Frag 本地权限提升漏洞，目前技术细节及PoC已公开，该漏洞源于 xfrm-ESP（自2017年）和RxRPC（自2023年）两个独立模块的逻辑缺陷。

该产品主要使用客户行业分布广泛，漏洞危害性极高，建议客户尽快做好自查及防护。

已通过恒脑AI代码审计智能体复现此漏洞。

```
test@ubuntu: ~/Desktop
test@ubuntu:~/Desktop$ uname -r
6.17.0-22-generic
test@ubuntu:~/Desktop$ id
uid=1000(test) gid=1000(test) groups=1000(test),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),100(users),114(lpadmin)
test@ubuntu:~/Desktop$ ./exp
# id
uid=0(root) gid=1000(test) groups=1000(test),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),100(users),114(lpadmin)
#
```

二、漏洞信息

Linux 内核是 Linux 操作系统的核心组件，负责进程调度、内存管理、网络协议栈和驱动管理等功能。

漏洞标题	Linux Kernel Dirty Frag 本地权限提升漏洞
漏洞处置等级	2级
漏洞类型	内存缓冲区操作限制不当
影响目标	
影响厂商	Red Hat / IBM、Canonical、SUSE、AlmaLinux OS Foundation、Fedora Project、Arch Linux、Debian
影响产品	RHEL、CentOS Stream、Fedora、Ubuntu、openSUSE、SUSE Linux Enterprise、AlmaLinux、Arch Linux、Debian
影响版本	xfrm-ESP: cac2661c53f3（2017-01-17）至今所有上游内核；RxRPC: 2dc334f1a63a（2023-06）至今所有上游内核。已知受影响发行版版本包括：Ubuntu 24.04.4（6.17.0-23-generic）、RHEL 10.1（6.12.0-124.49.1.el10_1.x86_64）、openSUSE Tumbleweed（7.0.2-1-default）、

	CentOS Stream 10 (6.12.0-224.el10.x86_64)、AlmaLinux 10 (6.12.0-124.52.3.el10_1.x86_64)、Fedora 44 (6.19.14-300.fc44.x86_64)
安全版本	官方暂未发布安全版本。上游内核已合入修复补丁 (commit: f4c50a4034e62ab75f1d5cdd191dd5f9c77fdff4)，等待各发行版 backport。
漏洞编号	
CVE编号	未分配
CNVD编号	未分配
CNNVD编号	未分配
CVSS3.1评分	7.8
漏洞危害等级	高危
CVSS向量	
访问途径 (AV)	本地
攻击复杂度 (AC)	低
所需权限 (PR)	低
用户交互 (UI)	不需要用户交互
影响范围 (S)	不变
机密性影响 (C)	高
完整性影响 (I)	高
可用性影响 (A)	高
威胁状态	
Poc情况	已发现

Exp情况	未发现
在野利用	未发现
研究情况	已复现

三、修复方案

官方修复方案

官方暂未发布补丁。上游内核已合入修复补丁，在 `esp_input/esp6_input` 的 `skip_cow` 分支中检查 `SKBFL_SHARED_FRAG` 标志，确保 `splice` 引入的外部固定页始终进入 `skb_cow_data` 路径，阻止攻击者固定的页缓存页进入就地 AEAD 的目标 SGL。修复补丁 `commit: f4c50a4034e62ab75f1d5cdd191dd5f9c77fdff4`。各发行版 backport 后请及时更新至最新版本。

信息来源

: <https://git.kernel.org/pub/scm/linux/kernel/git/netdev/net.git/commit/?id=f4c50a4034e62ab75f1d5cdd191dd5f9c77fdff4>

临时缓解方案

临时缓解方案（基于漏洞暴露面的保守缓解）：可通过禁用存在漏洞的内核模块来防止漏洞被利用。执行以下命令禁用 `esp4`、`esp6` 和 `rxrpc` 模块：`sh -c "printf 'install esp4 /bin/false install esp6 /bin/false install rxrpc /bin/false ' > /etc/modprobe.d/dirtyfrag.conf; rmmmod esp4 esp6 rxrpc 2>/dev/null; true"`。注意：禁用这些模块可能会影响 IPsec ESP 加密和 RxRPC 远程过程调用功能。

信息来源：<https://www.openwall.com/lists/oss-security/2026/05/07/8>

四、参考资料

<https://www.openwall.com/lists/oss-security/2026/05/07/8>

<https://github.com/V4bel/dirtyfrag>

<https://git.kernel.org/pub/scm/linux/kernel/git/netdev/net.git/commit/?id=f4c50a4034e62ab75f1d5cdd191dd5f9c77fdff4>